LAB 5: SBOM / CVE / Patch Management & Vulnerability Decision

Sistem 1: Genel Sürüm — Şişeleme Hattı Yazılım Parça Listesi (SBOM) ve CVE Yönetimi

1. Yazılım Parça Listesi (SBOM) ve Zafiyet Matrisi

Bileşen / Yazılım	Versiyon	İlişkili CVE / Zafiyet	CVSS Skoru	Geçici Telafi Edici Kontrol (Mitigation)
PLC TCP/IP Stack	v2.1.0	CVE-2023-XXXX (RCE)	**9.8 (Kritik)**	OT Güvenlik Duvarında (FW) Port 502 kısıtlaması & Deep Packet Inspection.
HMI Çalışma Zamanı	v4.0.1	CVE-2022-YYYY (XSS)	**6.1 (Orta)**	Girdi doğrulama kısıtlaması, varsayılan kimlik bilgilerinin değiştirilmesi.
Safety PLC Firmware	v1.0.4	Bilinen zafiyet yok	**0.0 (Temiz)**	Fiziksel programlama anahtarı (Key-switch) RUN modunda kilitli.

2. Yama Değerlendirme ve Karar Mekanizması (Vulnerability Decision Tree)

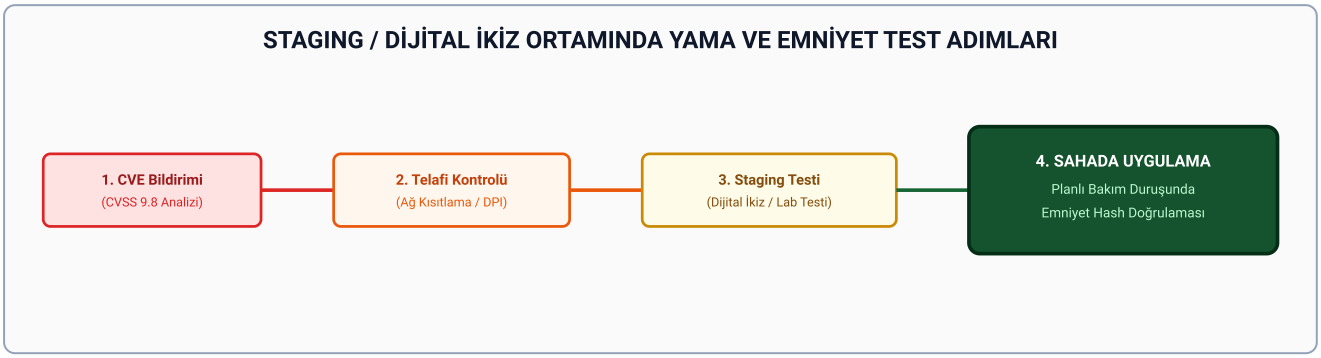
3 Koşullu Zafiyet Kontrolü

1. Bileşen sistemde mevcut mu? (Evet)
2. Zafiyetli versiyon mu çalışıyor? (Evet)
3. Saldırı yüzeyi erişilebilir mi? (Erişilebilir - Telafi Edici Kontrol Şart).

OT Ortamında Doğrudan Yama Yapmama İlkesi

Endüstriyel tesislerde anlık duruş maliyetleri ve sertifikasyon riskleri nedeniyle acil yama yerine önce ağ seviyesinde izolasyon ve planlı bakım duruşu beklenir.

3. Şişeleme Hattı Yama Test ve Doğrulama Akışı



LAB 5: SBOM / CVE / Patch Management & Vulnerability Decision

Sistem 2: Özel Sürüm — PaketPro 3000 Üçüncü Taraf Yazılım ve Yama Politikası

1. PaketPro 3000 Kritik SBOM Derlemesi ve Telafi Tedbirleri

Bileşen Unvanı	Varsayılan Kütüphane / Sürüm	Siber Risk & CVE Tanımı	Gerekli Telafi Edici Tedbir
Uzak Bakım Modülü Web Stack	OpenSSL v1.1.1f	CVE-2022-0778 (DoS / Sonsuz Döngü)	İnternet trafiği DMZ VPN arkasına alınır, doğrudan erişim engellenir.
Servo Sürücü Haberleşme Kütüphanesi	CANopen Stack v3.2	CVE-2021-ZZZZ (Buffer Overflow)	Sadece onaylı PLC IP adreslerinden gelen komutlara izin veren MAC filtresi.
Safety PLC Emniyet Logic	IEC 61508 SIL3 V2.0	CVE Bulunmuyor	Fiziksel Key-Switch ve CRC Kontrol toplamı (Checksum) doğrulaması.

2. Emniyet Doğrulaması ve Yama Sonrası Güvenlik Prosedürü

1. Emniyet CRC / Hash Kontrolü

Herhangi bir yazılım veya firmware güncellemesi sonrası Safety PLC içerisindeki SIL3 mantık bloklarının Checksum değeri orijinal değerle birebir eşleştirilmelidir.

2. Fiziksel Fonksiyon Testi

Yama uygulandıktan sonra makine üretime alınmadan önce ışık perdesi kesme ve E-Stop reaksiyon süreleri (ms cinsinden) yeniden ölçülür.

3. PaketPro 3000 Yama Yaşam Döngüsü ve Karar Ağacı

